

Credential Guard und Protected User

Plan

Login-Daten sind das bevorzugte Einfallstor für alle Arten von Angriffen auf System und ganze Netze. Schutzmechanismen für Windows umfassen...

- Credential Guard
- Protected Users Security Group

Diese schauen wir uns geneauer an. Wie man sie implementiert und was für Funktionen diese haben

Credential Guard

Normalerweise speichert Windows deine Passwörter oder „Anmelde-Tokens“ (digitale Schlüssel) im Arbeitsspeicher. Wenn sich ein Hacker Zugriff auf dein System verschafft, könnte er diese Schlüssel stehlen.

Credential Guard nutzt Virtualisierung, um diese sensiblen Daten in einem isolierten Bereich zu verstecken.

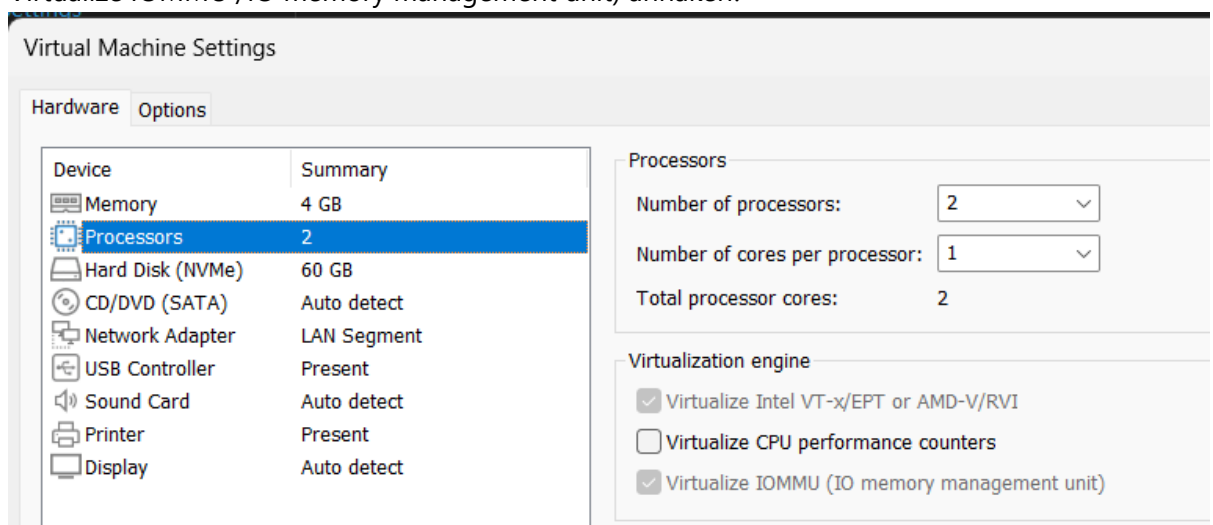
Der Hauptzweck ist der Schutz vor Identitätsdiebstahl. Es schützt vor allem gegen

- Pass-the-Hash: Ein Angreifer stiehlt nicht dein Passwort, sondern den daraus berechneten Hash, um sich damit gegenüber anderen Servern als du auszugeben.
- Pass-the-Ticket: Ähnlich wie Pass-the-Hash, nur mit Kerberos-Tickets in Firmennetzwerken.

Konfiguration

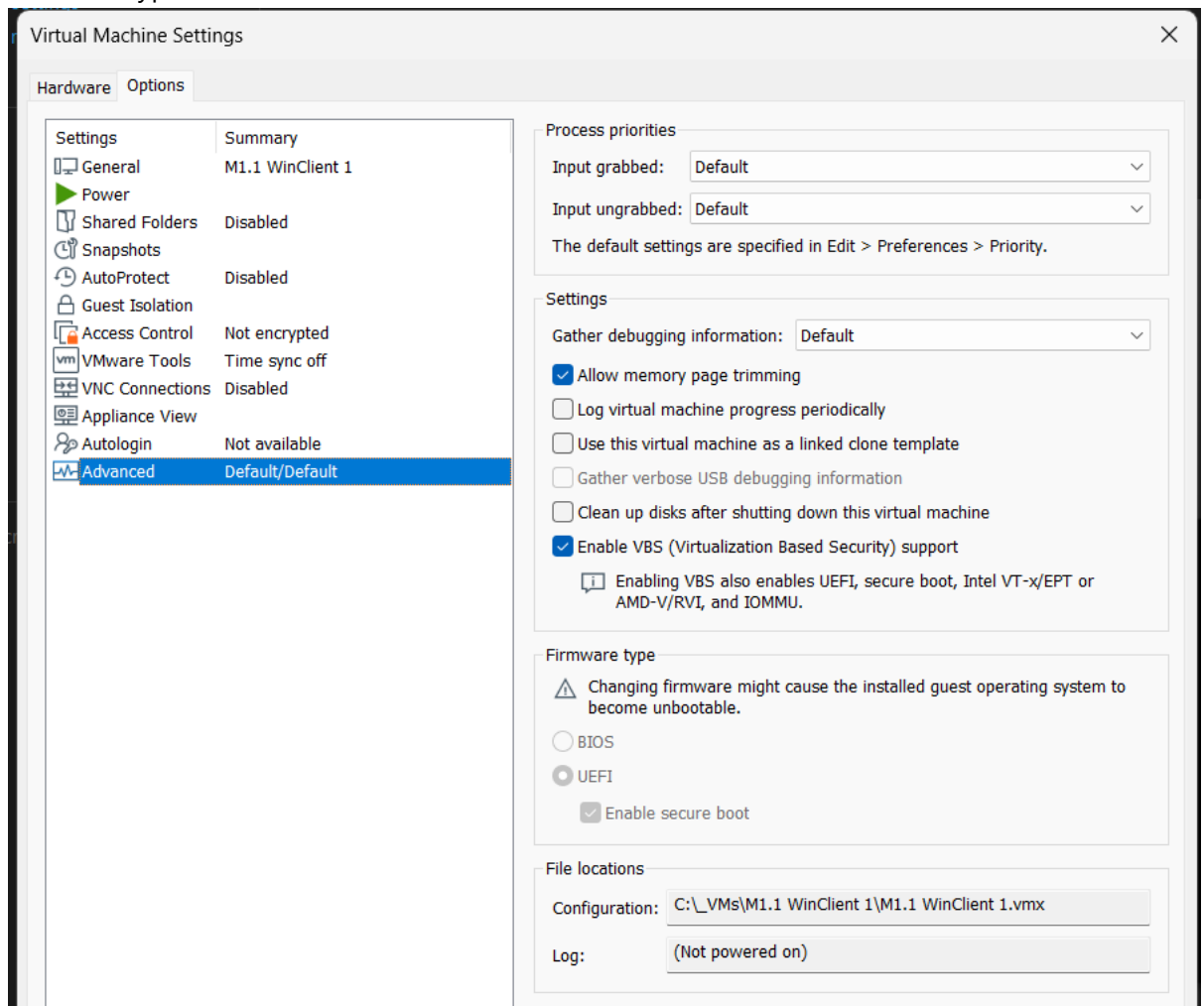
Vorraussetzungen (Es kann sein, dass VMWare das nicht supported): VM / Settings:

- Hardware / Processors:
 - Virtualize Intel VT-x/EPT or AMD-V/RVI
 - Virtualize IOMMU /IO memory management unit) anhängen!



- Options / Advanced:

- Settings / Enable VBS (Virtualization Based Security) support
- Firmware type / UEFI + Enable secure boot anhacken!



VBS enablen mit einer GPO: Unter Group Policy Management folgende Policy suchen: Computer Configuration\Policies\Administrative Templates\System\Device Guard

Turn On Virtualization Based Security

Previous Setting

Next Setting

☐ Not Configured
 Comment:

☒ Enabled

☐ Disabled

Supported on:

At least Windows Server 2016, Windows 10

Options:

Select Platform Security Level:

Secure Boot and DMA Protection

Virtualization Based Protection of Code Integrity:

Enabled without lock

☐ Require UEFI Memory Attributes Table

Credential Guard Configuration:

Enabled without lock

Secure Launch Configuration:

Enabled

Help:

Specifies whether Virtualization Based Security is enabled.

Virtualization Based Security uses the Windows Hypervisor to provide support for security services. Virtualization Based Security requires Secure Boot, and can optionally be enabled with the use of DMA Protections. DMA protections require hardware support and will only be enabled on correctly configured devices.

Virtualization Based Protection of Code Integrity

This setting enables virtualization based protection of Kernel Mode Code Integrity. When this is enabled, kernel mode memory protections are enforced and the Code Integrity validation path is protected by the Virtualization Based Security feature.

The "Disabled" option turns off Virtualization Based Protection of Code Integrity remotely if it was previously turned on with the "Enabled without lock" option.

The "Enabled with UEFI lock" option ensures that Virtualization

OK

Cancel

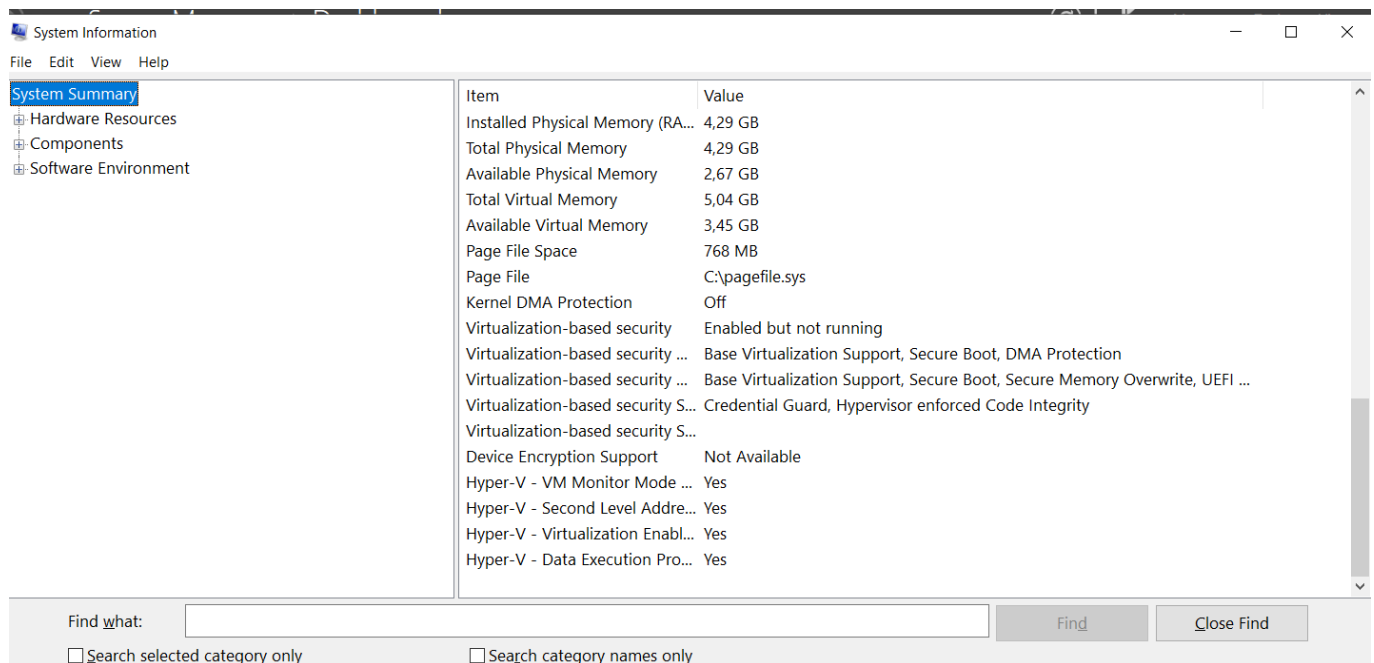
Apply

Testen

msinfo.exe:

Kernel-DMA-Schutz	Aus
Virtualisierungsbasierte Sicherheit	Wird ausgeführt...
Virtualisierungsbasierte Sicherheit – erforderliche Sicherheitseigenschaften	Allgemeine Virtualisierungsunterstützung, Sicherer Start, DMA-Schutz
Virtualisierungsbasierte Sicherheit – verfügbare Sicherheitseigenschaften	Allgemeine Virtualisierungsunterstützung, Sicherer Start, DMA-Schutz, UEFI-Co...
Virtualisierungsbasierte Sicherheit – konfigurierte Dienste	Credential Guard, Durch Hypervisor erzwungene Codeintegrität, Sicherer Start
Virtualisierungsbasierte Sicherheit – ausgeführte Dienste	Credential Guard, Durch Hypervisor erzwungene Codeintegrität
Windows Defender-Anwendungssteuerungsrichtlinie	Erzwingen
Windows Defender-Anwendungssteuerungs-Richtlinie für den Benutzermodus	Aus
Unterstützung der Geräteverschlüsselung	Ursachen dafür, dass die automatische Geräteverschlüsselung nicht erfolgreic...
Es wurde ein Hypervisor erkannt. Features, die für Hyper-V erforderlich sind, ...	

Falls die Einstellungen für die Voraussetzungen nicht angezeigt werden in VMWare wird VBS nicht supported und msinfo sieht so aus:

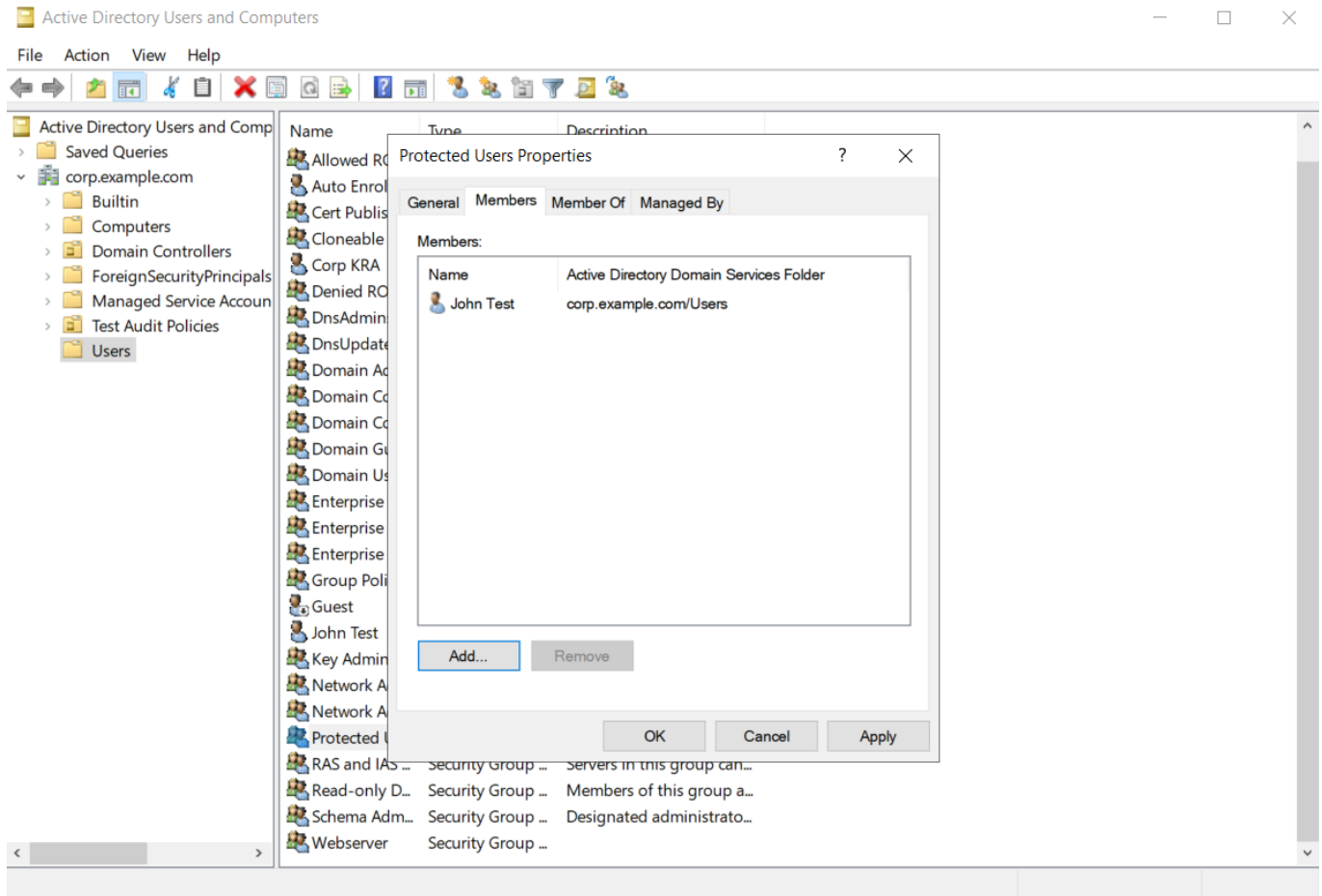


Protected User

Es handelt sich um eine spezielle Sicherheitsgruppe im Active Directory. Wenn du einen Benutzer in diese Gruppe verschiebst, wendet Windows automatisch bestimmte Sicherheitsregeln für dieses Konto an. Wie z.B.

- NTLM wird als Anmeldemethode komplett blockiert. Nur Kerberos ist erlaubt
- Verkürzte Ticket Expiry Time für das TGT
- Passwörter werden nicht mehr im Cache gespeichert

Um einen User in die Gruppe der Protected User hinzuzufügen, muss man diesen lediglich in die AD-Gruppe "Protected Users" hinzufügen.



Testen von Protected Usern mit Mimikatz

Installation von "Mimikatz"

- <https://github.com/gentilkiwi/mimikatz/releases>

Der download kann Probleme machen:

- Microsoft kann es als Virus erkennen, mit 7zip hat es bei mir funktioniert (7zip muss auch installiert werden) [Download](#)

- Mimikatz auf dem Lokalen Rechner für alle User zugänglich abspeichern.

User fürs Testen erstellen

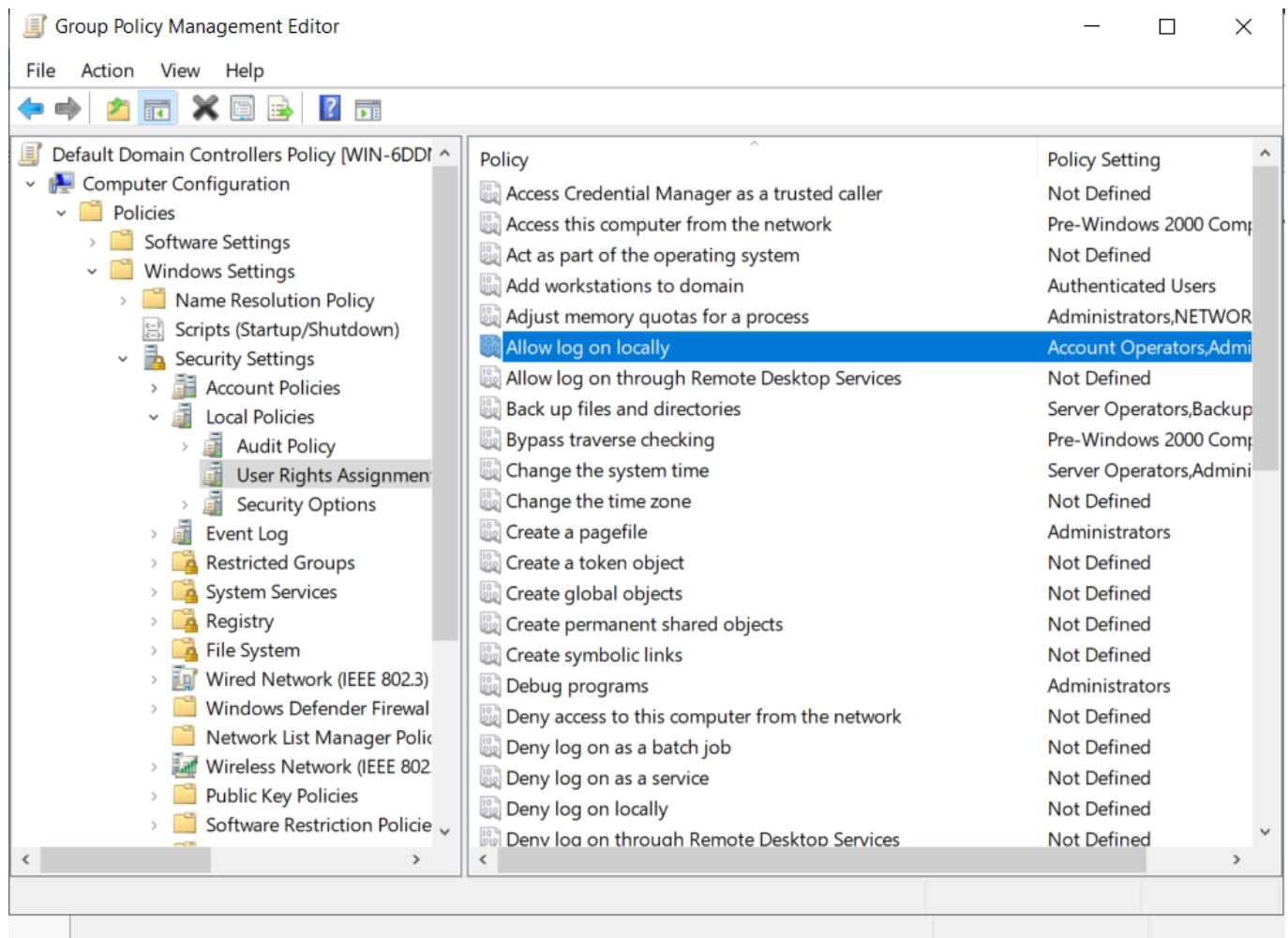
1. "secure user" erstellen

- Active directory user and computer
- neuer user
- teil der Gruppe "**Protected User**"

2. "unsecure user" erstellen

- Active directory user and computer
- neuer user

Falls die User sich direkt an einem Domain Controller anmelden können sollen, um keinen extra client PC erstellen zu müssen muss die "default domain Controller Policy" angepasst werden.



wie im screenshot beschrieben die "default domain controller policy" mit edit bearbeiten. Die Gehighlightete regel mit den 2 neuen Usern ergänzen.

Mimikatz auf beiden Accounts ausführen

jeweils mit secure und einmal unsecure anmelden und mimikatz folgendermassen ausführen:

1. mimikatz als administrator ausführen.
2. Folgende Befehle in Mimikatz ausführen:

```
privilege::debug
```

und:

```
sekurlsa::logonpasswords
```

3. Output überprüfen:

- secure user

```
Authentication Id : 0 ; 6347891 (00000000:0060dc73)
Session           : Interactive from 6
User Name         : secure
Domain            : EXAMPLE
Logon Server      : WIN-6DDNHHHOAED
Logon Time        : 3/23/2026 8:31:29 PM
SID               : S-1-5-21-2566575397-2444899784-3693576581-1105

    msv :
        [00000003] Primary
        * Username : secure
        * Domain   : EXAMPLE
        * DPAPI    : 53ad8ef56f766b15a2caaef3df1cfcc9
    .
    tspkg :
    wdigest :
        * Username : secure
        * Domain   : EXAMPLE
        * Password : (null)
    kerberos :
        * Username : secure
        * Domain   : EXAMPLE.COM
        * Password : (null)
    ssp :
    credman :
    cloudap :
```

hier wird KEIN "NTLM" hash sichtbar da user "secure" teil der "Protected_User" Gruppe ist.

- unsecure user

```
Authentication Id : 0 ; 5181271 (00000000:004f0f57)
Session          : Interactive from 5
User Name        : unsecure
Domain           : EXAMPLE
Logon Server     : WIN-6DDNHHHOAED
Logon Time       : 3/23/2026 8:18:41 PM
SID              : S-1-5-21-2566575397-2444899784-3693576581-1106

msv :
  [00000003] Primary
  * Username : unsecure
  * Domain   : EXAMPLE
  * NTLM     : 33959f087f0acdc13d5df84e7258cc67
  * SHA1     : d0b44499967c73934e336cbe70eb2cf24a06646c
  * DPAPI    : 878dabdc2b4085be8e5085131a0458c5
tspkg :
wdigest :
  * Username : unsecure
  * Domain   : EXAMPLE
  * Password : (null)
kerberos :
  * Username : unsecure
  * Domain   : EXAMPLE.COM
  * Password : (null)
```

hier steht ein "NTLM" hash da user "unsecure" NICHT teil der "Protected_User" Gruppe ist.